

漏洞报告 VULN-04: CSRF跨站请求伪造

漏洞类型: CSRF跨站请求伪造

测试小组: 天亮了吗

被测小组: 天亮了吗

测试时间: 2026-08-23

测试环境: 本机 localhost / 127.0.0.1:5001

测试账号: 课程测试账号, 未使用真实个人密码

1. 基本信息

本报告针对阶段二任务4, 仅在授权的本机课程靶场中完成。

2. 漏洞位置

URL/接口: 登录、注册、上传、删除及 API 状态变更接口

请求方法: GET/POST/DELETE (按接口实际方法)

关键参数: username、password、filename、file、csrf_token (按任务适用)

所属功能: 状态变更

3. 正常请求

先使用正常账号和合法参数完成对应功能, 再仅修改一个测试参数。请求记录和页面证据见附件目录。

正常请求示例: 在本机浏览器访问对应页面, 提交课程测试账号或合法文件; 不包含真实密码、Cookie 或 Token。

4. 漏洞复现步骤

1. 启动本机网盘并登录课程测试账号。
2. 按任务说明构造单一无害测试参数。
3. 发送请求并记录状态码、页面、文件或会话变化。
4. 使用修复后的同一参数再次验证。

5. 攻击效果或异常现象

不携带 CSRF Token 调用 /api/register, 返回403; 错误 Token 的上传请求也被拒绝。

6. 漏洞原因分析

原状态变更接口未统一校验请求来源。

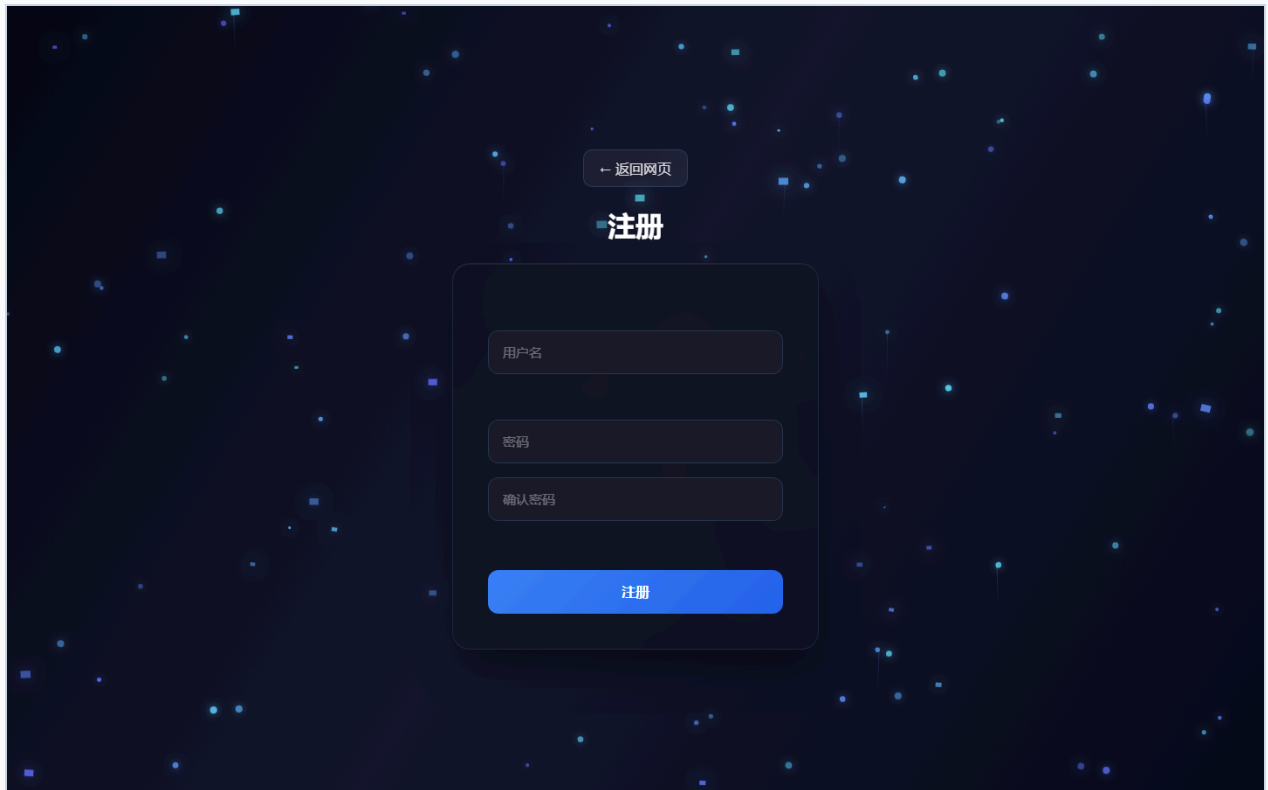
7. 影响范围

影响范围限于本机课程靶场及测试账号；不得外推为公网系统影响。具体后果取决于接口是否需要登录及资源归属。

8. 修复建议

Session 生成随机 Token；表单 hidden 字段和 X-CSRF-Token 请求头统一校验；Cookie 使用 SameSite=Lax。

9. 附件清单



Pretty-print ☐

```
[{"error": "\u8bf7\u6c42\u9a8c\u8bc1\u5931\u8d25\u5f0c\u8bf7\u5237\u65b0\u9075\u9762\u540e\u91cd\u8bd5"}]
```

上传文件

选择文件

Choose File

No file chosen

可选新文件名

留空则使用原文件名

上传文件

返回个人主页

Pretty-print ☐

```
{"csrf_token": "kuzklbuH5MLtODPBxM5yLI0I5DVpZorqbEJgBVwqZGA"}
```

任务 04 修复代码证据

gets.py:64-90

```
64
65
66 def csrf_token():
67     token = session.get("csrf_token")
68     if not token:
69         token = secrets.token_urlsafe(32)
70         session["csrf_token"] = token
71     return token
72
73
74 @app.context_processor
75 def inject_security_helpers():
76     return {'csrf_token': csrf_token}
77
78
79 def csrf_protected(view):
80     @wraps(view)
81     def wrapped(*args, **kwargs):
82         supplied = request.form.get("csrf_token") or request.headers.get("X-CSRF-Token")
83         expected = session.get("csrf_token")
84         if not expected or not supplied or not secrets.compare_digest(supplied, expected):
85             return jsonify({'error': "请求验证失败，请刷新页面后重试"}), 403
86         return view(*args, **kwargs)
87
88     return wrapped
89
90
```

gets.py:302-320

```
302 @csrf_protected
303 def api_register():
304     data = request.get_json(silent=True) or request.form
305     return _register(data.get("username", "").strip(), data.get("password", ""), data.get("confirm_password", ""))
306
307
308 @app.route("/upload", methods=["GET", "POST"])
309 def upload_file():
310     if "username" not in session:
311         return redirect("/login")
312     if request.method == "GET":
313         return render_template("upload.html")
314     supplied = request.form.get("csrf_token")
315     if not supplied or not secrets.compare_digest(supplied, session.get("csrf_token", "")):
316         return jsonify({'error': "请求验证失败，请刷新页面后重试"}), 403
317     result = _save_upload(request.files.get("file"), request.form.get("customName", ""))
318     return redirect("/listfiles") if result[1] == 200 else result
319
320
```